

CIS Benchmark para MySQL

da teoria à prática

*Como transformar uma demanda de segurança em um
processo reproduzível*

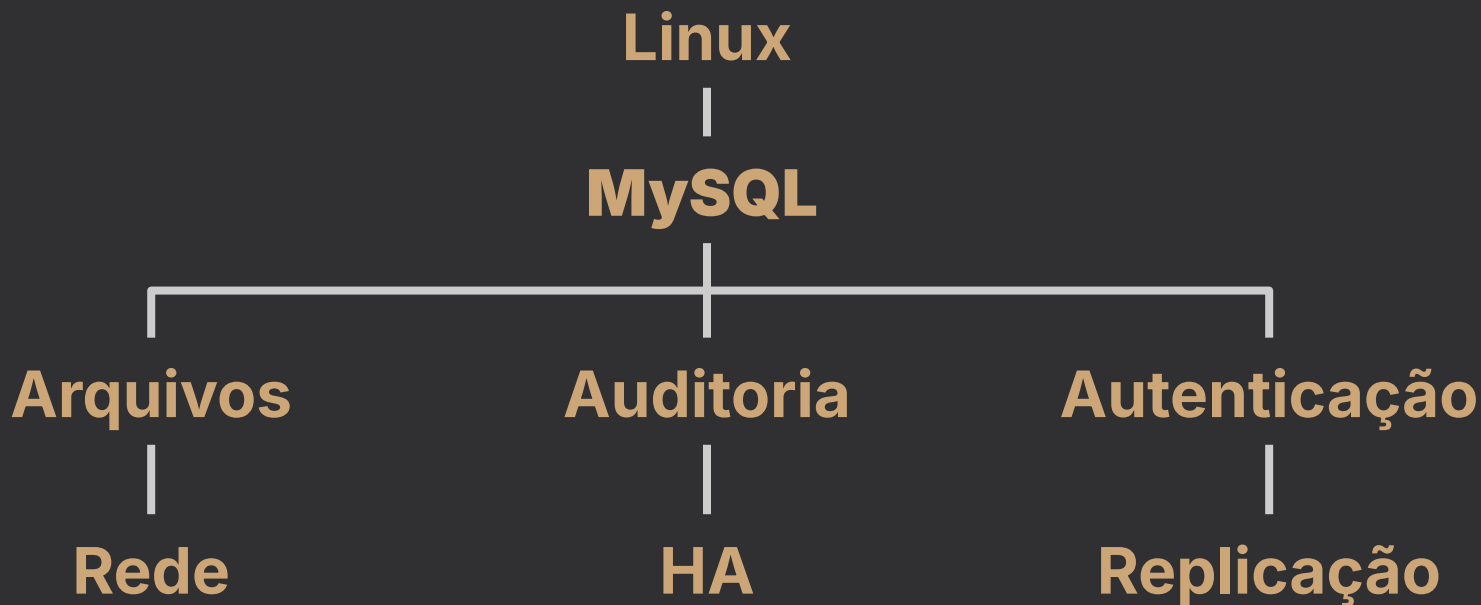
O nosso MySQL é seguro?!?

Eu não tinha um critério

**Eu precisava tornar a
pergunta verificável**

CLS Benchmark

O que ele verifica



O que o Benchmark realmente entrega

O Benchmark transforma boas práticas de segurança em recomendações verificáveis.

Uma referência para avaliar e fortalecer a configuração de uma tecnologia.

*É uma peça do programa de segurança,
não o programa inteiro*

CIS Oracle MySQL Community Server 9.7 Benchmark

v1.0.0 - 06-30-2026

Nem tudo é automatizável

É incluído um estado de avaliação para cada recomendação.

AUTOMATIZADO

Avaliação
automatizável

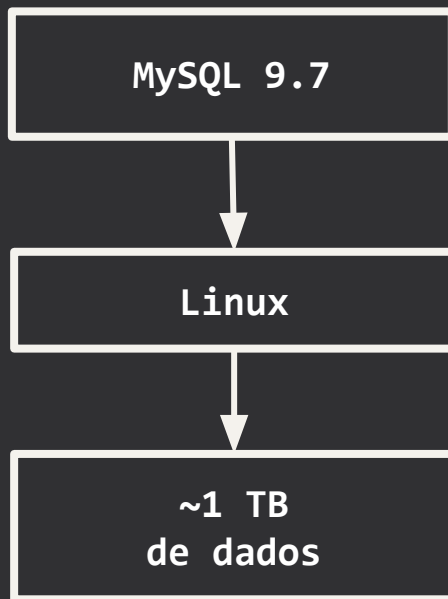
MANUAL

Avaliação
manual

PERFIL

Nível 1 / Nível 2

O ambiente do case



**Do benchmark and
assessment**

**Entender ⇒ Verificar ⇒
Evidenciar ⇒ Avaliar**

Como um controle realmente é avaliado

**O que precisa sair de
cada controle**

A primeira execução: manual

O que eu encontrei

38 CONTROLES

26 AUTOMATIZADOS	12 MANUAIS
---------------------	---------------

26 AUTOMATIZADOS

8 PASS

18 FAIL

**O choque: quantos
controles estavam fora
do esperado**

18 de 26

Um controle em detalhes

1.2 – Dedicated Least Privileged Account

Perfil
Automação

Level 1
Automated

O que verificar?



Como verificar?



O que espero?



Evidência?



Remediação?

Demo: verificando o controle

```
[root@localhost ~]# ps -ef | grep "^mysql.*$"
```

```
mysql          749          1  0 Sep15 ?           00:10:08 /usr/sbin/mysqld
```

```
[root@localhost ~]#
```

PASS ✓

Demo: execução automatizada

```
[root@localhost ~]# ps -ef | grep -q "^mysql.*$" \  
    && echo "1.2: PASS" \  
    || echo "1.2: FAIL"
```

1.2: PASS

```
[root@localhost ~]#
```

Do resultado à evidência

O CONTROLE

1.2

* Verificação

ps -ef ...

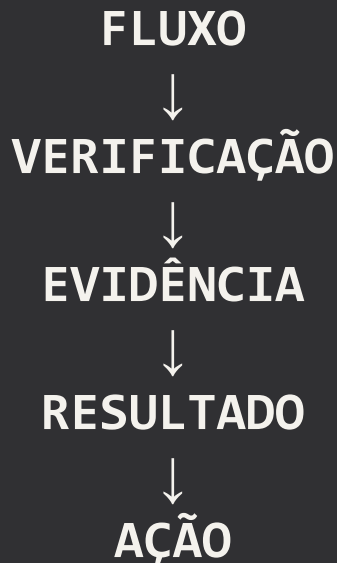
mysql ... **/usr/sbin/mysqld**

* Resultado: **PASS**

A EVIDÊNCIA

```
CONTROL,STATUS,EVIDENCE
1.1,FAIL,Databases not on Non-System Part
1.2,PASS,Dedicated least privileged acco
1.3,FAIL,MySQL command history not disab
1.4,PASS,MYSQL_PWD environment variable
1.5,PASS,Interactive login is disabled
1.6,PASS,MYSQL_PWD is not set in users' p
1.7,PASS,MySQL is running under a sandbox
2.1.1,FAIL,Backup policy not found
2.1.2,MANUAL,Verify Backups are Good
2.1.3,MANUAL,Secure Backup Credentials
2.1.4,MANUAL,The Backups Should be Proper
```

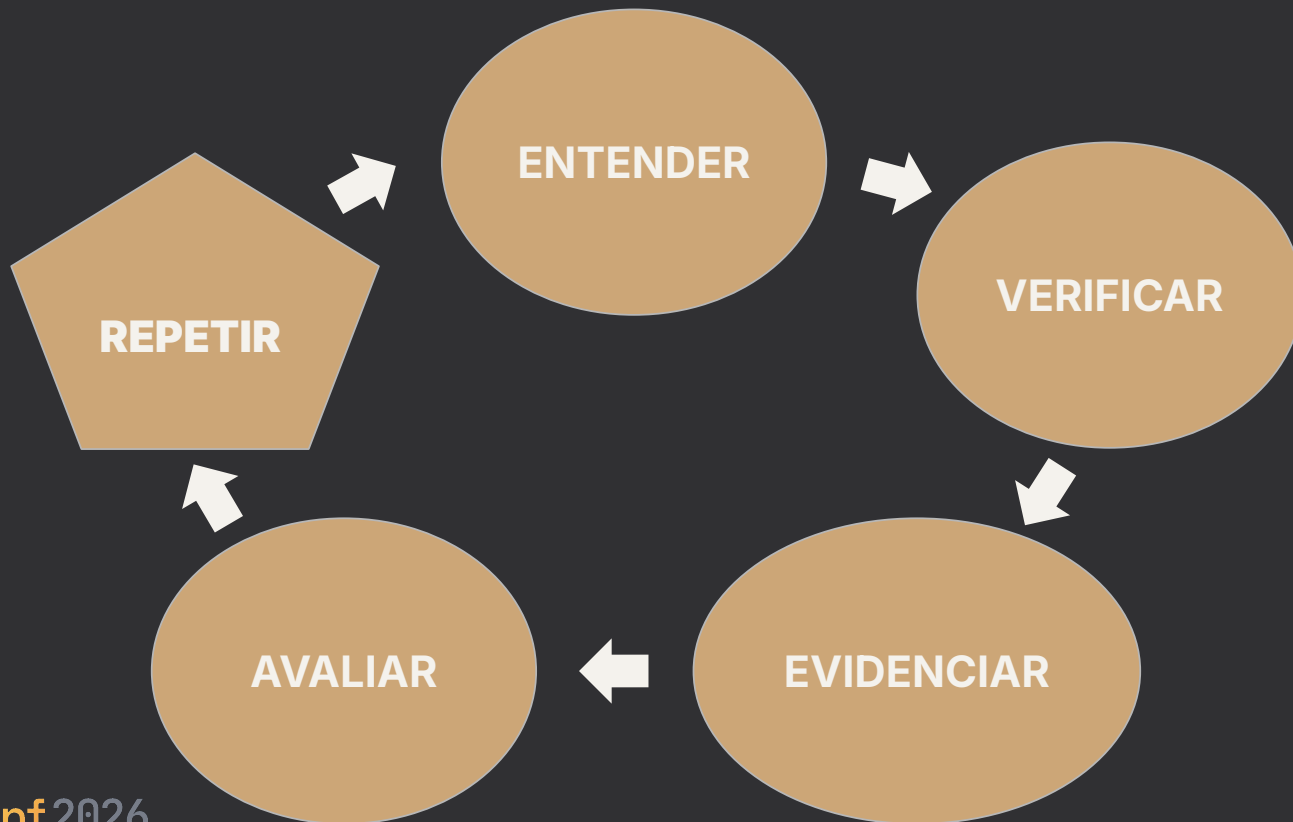
O relatório do assessment



Recomendação CIS Benchmark para MySQL 9.7		Type	Level	Configurado Corretamente	
				Sim	Não
1	Operating System Level Configuration				
1.1	Place Databases on Non-System Partitions	Manual	1	☐	☒
1.2	Use Dedicated Least Privileged Account for MySQL Daemon/Service	Automated	1	☒	☐
1.3	Disable MySQL Command History	Automated	2	☐	☒
1.4	Verify That the MYSQL_PWD Environment Variable is Not in Use	Automated	1	☒	☐
1.5	Ensure Interactive Login is Disabled	Automated	2	☒	☐
1.6	Verify That 'MYSQL_PWD' is Not Set in Users' Profiles	Automated	1	☒	☐
1.7	Ensure MySQL is Run Under a Sandbox Environment	Manual	2	☒	☐
2	Installation and Planning				
2.1	Backup and Disaster Recovery				
2.1.1	Backup Policy in Place	Manual	1	☐	☒
2.1.2	Verify Backups are Good	Manual	1	☐	☒
2.1.3	Secure Backup Credentials	Manual	1	☐	☒
2.1.4	The Backups Should be Properly Secured	Manual	1	☐	☒
2.1.5	Point-in-Time Recovery	Automated	2	☒	☐
2.1.6	Disaster Recovery (DR) Plan	Automated	2	☐	☒
2.1.7	Backup of Configuration and Related Files	Manual	1	☐	☒
2.2	Data Encryption				
2.2.1	Ensure Binary and Relay Logs are Encrypted	Automated	2	☐	☒
2.3	Dedicate the Machine Running MySQL	Manual	1	☒	☐
2.4	Do Not Specify Passwords in the Command Line	Manual	1	☒	☐
2.5	Do Not Pause Usernames	Manual	1	☒	☐

O que eu faria diferente hoje

O método que ficou



**Você também pode
começar**

Comece verificando

Escolha um MySQL.

Escolha um controle.

E comece.

Referências

- mysqlbrconf.com.br
- cisecurity.org
- github.com/trilha0/cis-benchmark-mysql

Sobre Mim



DBA MySQL e Oracle

- Arquiteto de Soluções
- Instrutor de Oracle Database Security
- Consultoria de Segurança
- +15 anos como DBA
- +25 anos na área de tecnologia

Porque a tecnologia move o Mundo!



www.linkedin.com/in/marcosaureliobraga

